

CWE AI Working Group: New Entry Subgroup

November 21, 2025

Attendance

Steve Christey	Carolina Rocha	Tod Beardsley
Erick Galinkin	Sara El Filali	Bamidele Ajayi
Martin Hodo	Earl Lynn Tipton	
Sasha Romanosky	John Cotter	

Agenda

- Status Updates
- CWE Release Information
- Work Planning

Meeting Notes:

Status Updates

New subgroup member introductions: John Cotter (Bentley Systems, security architect), Earl Lynn Tipton (Intel, offensive security researcher), and Sara El Filali (cybersecurity specialist) introduced themselves and expressed interest in contributing to observed-example curation and broader CWE AI efforts. Steve will double-check and confirm any additional new subgroup members.

Next CWE release: Steve noted the next CWE release is 4.19.

This document includes content generated with the assistance of Microsoft Teams Copilot, a generative AI tool. Microsoft Teams Copilot was used to generate the initial draft of the meeting minutes and provide suggestions for summarizing key discussion points. All AI-generated content has been reviewed and edited by the CVE Program prior to publishing. Please report any inaccuracies or other issues to the CVE Program.

CDR note: Steve created and shared a Content Development Repository (CDR) issue to coordinate nominations and discussion for CVE observed examples relevant to AI/ML. Members are encouraged to suggest candidates in the meeting chat and directly within the CDR issue for tracking and review.

CWE Release Information (CWE 4.18)

Observed-example alignment: The working group will curate CVE observed examples that are well-explained, well-understood, and clearly mapped to the appropriate CWE entries to improve educational value for readers, with an emphasis on AI/ML-relevant contexts. Collections under a single CWE should show diversity across product types, variations in mistakes and attack surfaces, input sources, and technologies/languages.

Example calibration: A live assessment of a candidate mapped to command/OS command injection highlighted the importance of using references that directly describe the flaw; commits that remove functionality can complicate interpretation of the underlying weakness. The candidate remains under consideration pending documentation of clear rationale and references.

Timeline context: Preparatory work for release content will proceed asynchronously due to year-end attendance constraints. Meetings on December 19 and January 2 are canceled; the group will meet on December 5 and regroup on January 9 to confirm inclusions and finalize documentation supporting the 4.19 cycle. Alex Summers will update the calendar series and coordinate scheduling.

Work Planning

Workflow and tooling: Steve demonstrated a raw CVE report covering roughly the past year with CWE mappings and AI product indicators derived via keyword/regex searches.

Planned improvements include adding direct URLs to CVE records, expanding the timeframe to multiple years, and targeting 1–3 candidate observed examples per CWE for deeper analysis and group review. The CDR issue will serve as the focal point for nominations, references, and decision tracking.

Selection criteria: The group emphasized accurate CWE mapping, strong sourcing, reproducibility where feasible, clear articulation of exploit/impact, and instructional value in AI/ML deployments.

Preference is given to examples where the AI/ML component is integral to the weakness rather than incidental to a generic bug, while recognizing that AI systems often surface standard software weaknesses worth documenting in AI contexts.

Component perspective: Members discussed describing vulnerabilities via AI system components (training, fine-tuning, inference, RAG, system prompts, interfaces) to improve clarity, noting that CWE coverage for architecture/design is less systematic, and that some weaknesses may reflect design decisions (e.g., trusting AI output without validation).

Action Items:

- **CVE Observed Examples Report:** Regenerate and upload the updated CVE observed examples report to the CDR issue for group review and discussion. (Steve)
- **December Meeting Schedule:** Cancel the December 19th and January 2nd modification group meetings and update the calendar series accordingly. (Steve)